

30. hét - Kiberbiztonság az ipari automatizálásban

Zero Trust és IEC 62443 • Felnőtt oktatás • digitális • 1 x 45 perc

A hét mottója: „A legbiztonságosabb PLC az, amely nemcsak jól vezérel, hanem megfelelően is védett.” Tanulási cél: az ipari kiberbiztonság, a Zero Trust szemlélet és az IEC 62443 alapelveinek megismerése.

A világ nagy kérdése

Hogyan védhetők meg a PLC-k, HMI-k, SCADA rendszerek és ipari hálózatok úgy, hogy közben a termelés megbízhatóan működjön? Az OT-rendszereknél a biztonság nemcsak adatvédelmi kérdés: a rendelkezésre állás és a fizikai folyamat biztonsága is fontos.

Történeti kitekintés

Időszak	Jellemző változás
1970-es évek	Jellemzően zárt, elszigetelt PLC-rendszerek.
1990-es évek	Ethernet és vállalati hálózati kapcsolatok terjedése.
2000-es évek	IT és OT rendszerek egyre szorosabb összekapcsolása.
2010-es évektől	Célzott ipari kibertámadások nagyobb figyelmet kapnak.
Napjaink	IIoT, távoli elérés, felhő és Zero Trust szemlélet.

1. IT és OT

Az IT elsősorban információs rendszerekkel és adatokkal foglalkozik. Az OT (Operational Technology) közvetlenül fizikai folyamatokat vezérel: PLC, HMI, SCADA, hajtások és ipari hálózatok tartozhatnak ide. OT környezetben egy kiesés termelésleállást vagy veszélyes folyamatállapotot is okozhat.

2. A CIA-hármas

Fogalom	Ipari jelentés
Confidentiality - bizalmasság	Csak jogosult személy vagy rendszer férjen hozzá az információhoz.
Integrity - sértetlenség	A program, beállítás és adat ne módosulhasson észrevétlenül vagy jogosulatlanul.
Availability - rendelkezésre állás	A vezérlési és felügyeleti rendszer akkor legyen elérhető, amikor szükség van rá.

3. Zero Trust

A Zero Trust szemlélet egyszerűen így foglalható össze: „Soha ne bízz, mindig ellenőrizz!” Nem tekintünk automatikusan megbízhatónak egy felhasználót vagy eszközt csak azért, mert a belső hálózaton van. Azonosítás, jogosultság, eszközállapot és a szükséges hozzáférés ellenőrzése fontos.

4. Legkisebb jogosultság elve

Minden felhasználó és rendszer csak ahhoz férjen hozzá, amire a feladatához valóban szüksége van. Egy SCADA-operátornak például nem feltétlenül kell PLC-programot módosítania, egy karbantartónak pedig nem szükséges minden vállalati adatbázishoz hozzáférnie.

5. Hálózati szegmentálás

Az ipari hálózatot célszerű zónákra bontani. A PLC-k, HMI-k és SCADA szerverek ne legyenek szükségtelenül közvetlenül elérhetők más hálózatokból. A zónák közötti adatforgalmat szabályozott átjárók, tűzfalak és engedélyezett kommunikációs útvonalak kezelhetik.

Egyszerű védelmi gondolat: Internet / vállalati IT → szabályozott határ → ipari DMZ → OT/SCADA → vezérlési zóna → PLC. A konkrét kialakítás mindig kockázat- és rendszerfüggő.

6. IEC 62443 szerepe

Az IEC 62443 szabványsorozat az ipari automatizálási és vezérlőrendszerek kiberbiztonságával foglalkozik. A szemlélet többek között rendszerszintű kockázatkezelést, zónák és kommunikációs kapcsolatok (conduits) kialakítását, valamint műszaki és szervezeti követelményeket használ.

7. IEC 62443 alapvető követelménycsoportok

- Azonosítás és hitelesítés.
- Használat és jogosultság szabályozása.
- Rendszerintegritás.
- Adatbizalmasság.
- Korlátozott adatáramlás.
- Eseményekre adott időbeni válasz.
- Erőforrások rendelkezésre állása.

8. Gyakori ipari kockázatok

- Alapértelmezett vagy közösen használt jelszó.
- Nem szabályozott távoli hozzáférés.
- Ismeretlen USB-adathordozó.
- Elavult, nem kezelt eszköz vagy szoftver.
- Feleslegesen nyitott hálózati szolgáltatás.
- Túl széles felhasználói jogosultság.
- Nem megfelelő mentési és helyreállítási eljárás.

9. Biztonságos karbantartói hozzáférés

Távoli karbantartásnál fontos lehet a névre szóló felhasználó, többtényezős hitelesítés, időben korlátozott hozzáférés, naplózás és az, hogy csak a szükséges célrendszer legyen elérhető. A hozzáférés ne legyen állandó és korlátlan.

10. Mentés és helyreállítás

A kiberbiztonság nem csak a támadás megakadályozása. A PLC-programok, HMI/SCADA konfigurációk és fontos beállítások ellenőrzött mentése segíti a helyreállítást. A mentést időnként visszaállítási próbával is érdemes ellenőrizni.

Kulcsgondolat: az ipari kiberbiztonság réteges védelem. Nincs egyetlen eszköz, amely önmagában mindent megold: hálózati kialakítás, jogosultság, frissítés, mentés, naplózás és emberi fegyelem együtt szükséges.

Önellenőrző kérdések

- Mit jelent az OT?
- Mi a CIA-hármas három eleme?
- Mit jelent a Zero Trust?
- Miért fontos a legkisebb jogosultság elve?
- Mi a hálózati szegmentálás célja?
- Mivel foglalkozik az IEC 62443?
- Miért fontos a mentés és a helyreállítási próba?

IAP-kihívás: tervezz biztonsági zónákat egy kis automatizált üzemhez! Legyen vállalati IT, SCADA, két PLC, HMI és távoli karbantartás. Rajzold be, mely rendszerek kommunikálhatnak egymással, és írd legalább 5 védelmi szabályt.